

CSE446: Blockchain & Cryptocurrencies

Lecture – 19: Blockchain Security, Governance and Advanced Concepts



Inspiring Excellence

Agenda

- Attacks on Blockchain
- Blockchain Governance
- Advanced concepts

Attacks on Blockchain

- Transaction censoring attack
- 51% attack
- Double-spending attack
- Selfish mining attack (Block withholding attack)
- Sybil attack
- DDoS attack

Transaction censoring attack

- Blocking (censoring) a transaction from a certain address (people)
- Malicious validating (full) nodes:
 - As long as there are majority of honest nodes ($>50\%$), the transactions will be propagated
 - Mind you, a malicious node cannot affect the blockchain in this way
- Malicious mining nodes:
 - If malicious mining nodes censor transactions, they would still be included in a block mined by an honest node

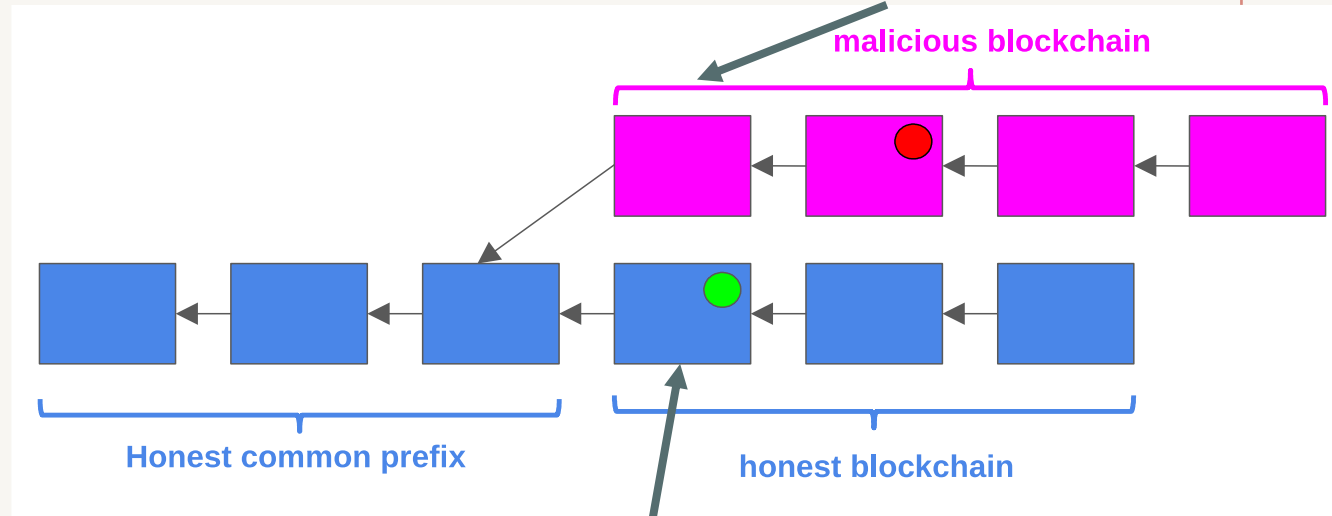
51% attack

- A group of malicious nodes can collude to launch the infamous 51% attack
- It happens in PoW-based blockchains, if a single miner's hashing power accounts for more than 50% of the total hashing power of the entire blockchain
- In PoS blockchain, 51% attack may also occur if the number of coins owned by a single miner is more than 50% of the total blockchain
- Controlling a majority (51%) can cause a deliberate "fork" in the blockchain
 - A fork is where the attacker causes previously confirmed blocks to be invalidated by forking below them and re-converging on an alternate chain
 - With sufficient power or tokens, attackers can generate blocks at a faster rate than honest miners
 - This will result in the invalid chain to be longer than the shorter chain, ultimately becoming the main chain

Double~spending attack

- Double spending means the act of using the same currency more than once
- Double-spending one's own transactions is profitable
 - if by invalidating a transaction the attacker can get an irreversible exchange payment or product without paying for it
- To deter this attack, wait for the finality
 - For bitcoin it is 6 confirmations ~ 1 hour

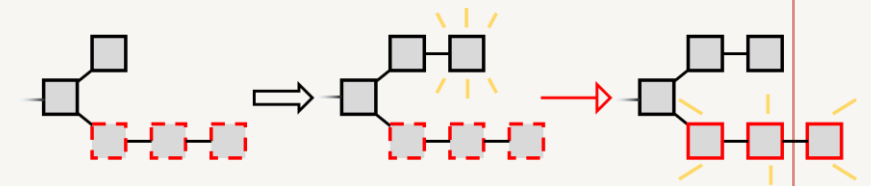
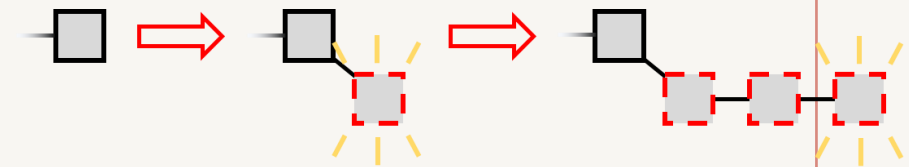
After receiving the good, launches the double spending attack here



Attacker pays here to buy something

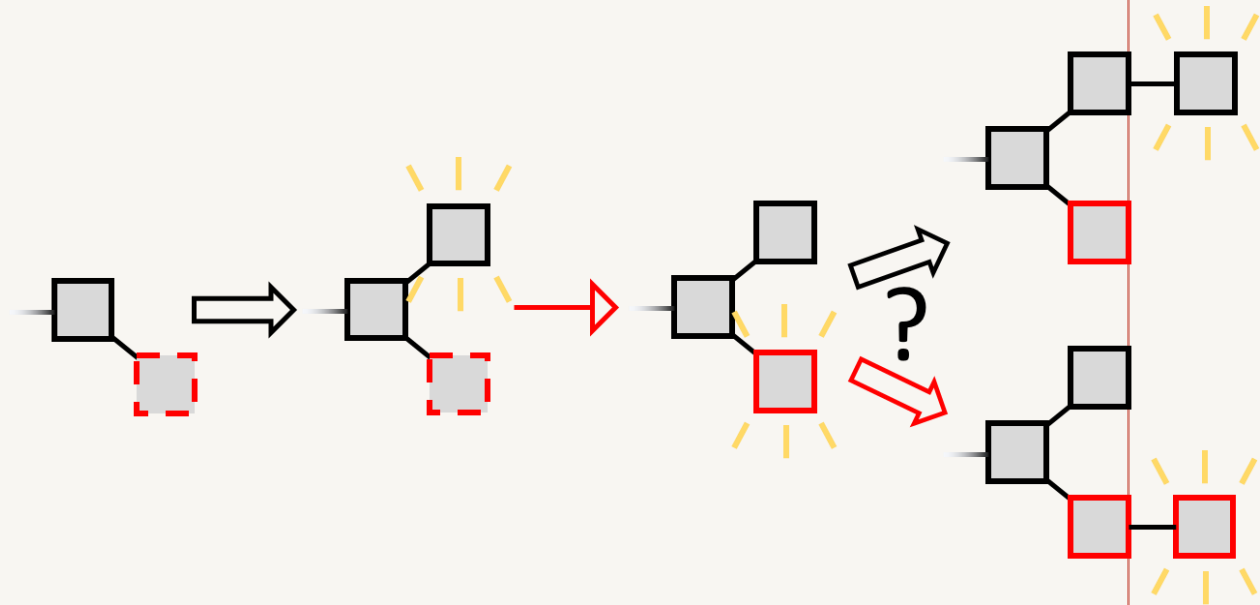
Selfish mining (block withholding) attack

- An attack to PoW blockchain
- The attacker (selfish miner) privately generates valid blocks and extends their own chains secretly, forming a secret branch
- The selfish miner continues to extend her secret branch until the public chain is one step behind
- Then she publishes her secret chain
- Since the secret chain is longer, the other parties consider it the main chain, so now everyone is following the selfish miner's blocks
- The blocks generated by the other miners are ignored
- The selfish miner can reap rewards for multiple blocks together



Selfish mining attack

- But there is a caveat to this strategy - when first forming her secret chain, the selfish miner takes a risk
- If she generated the first secret block and then another miner generated a block at the same time
 - it will be a race between two branches, and it is not guaranteed if the selfish miner would win



Sybil attack

- In a Sybil attack, an attacker can duplicate her identity as required in order to achieve illicit advantages
- This can be as simple as one person creating multiple social media accounts
- The word "Sybil" in the name comes from a case study about a woman named Sybil Dorsett, who was treated for Dissociative Identity Disorder – also called Multiple Personality Disorder
- Within a blockchain system, a sybil attack implicates the scenario when an adversary can create/control as many nodes as required within the underlying P2P network to exert influence on the distributed consensus algorithm
 - Having more nodes could improve her probability to solve the PoW algorithm or to be selected as a leader to propose a block in a PoS system

Sybil attack

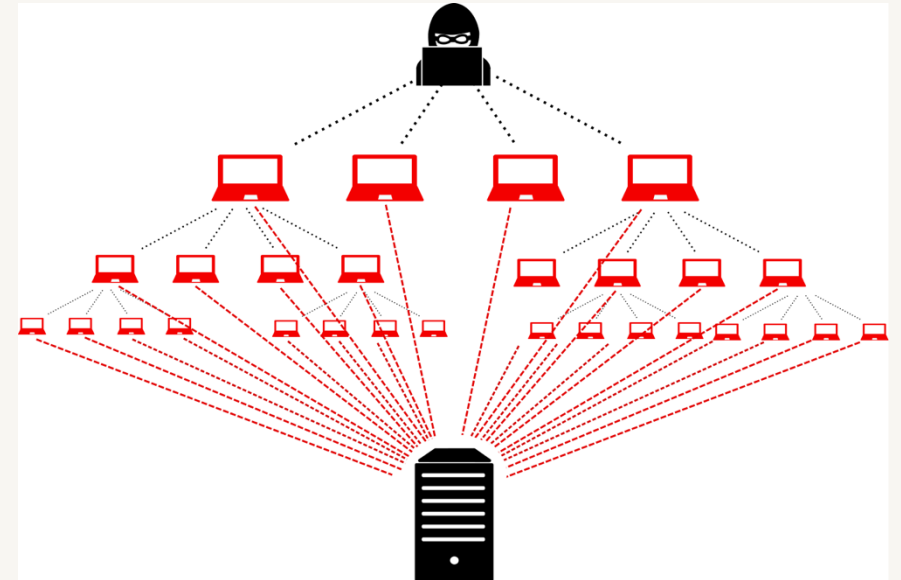
- Attackers may be able to out-vote the honest nodes on the network if they create enough fake identities (or Sybil identities)
- They can then refuse to receive or transmit blocks, effectively blocking other users from a network
- In really large-scale Sybil attacks, where the attackers manage to control the majority of the network computing power or hash rate, they can carry out a 51% attack
- In such cases, they may change the ordering of transactions, and prevent transactions from being confirmed
- They may even reverse transactions that they made while in control, which can lead to double spending

Sybil attack

- Consensus algorithms must be designed in such a way that they can deter any Sybil attack
- These consensus algorithms don't actually prevent Sybil attacks, they just make it very impractical for an attacker to successfully carry out a Sybil attack
- For example, when using PoW algorithms, the probability of creating a valid block is proportional to the total hashing power of all (sybil) nodes
- That means attackers actually need to own the computer power required to create a new block, which makes it very difficult and costly for an attacker to do
- Since mining is so intensive, miners have a very strong incentive to keep mining honestly, instead of attempting a Sybil attack

DDoS attack

- DDoS stands for Distributed Denial-of-Service attack
- The attack is distributed over a large network of compromised endpoints
- This large network is called a botnet, which resembles an army under the command of the attacker
- The goal of the attack is to cause a denial of service for the users of the target system
- This is accomplished by prompting each of the members in the botnet to start sending messages to the same target at the same time
- This flood of incoming messages is intended to deplete the target resources to cause the system to slow down or crash entirely, and to deny the service from its users.



DDoS attack in blockchain

- In the blockchain space, the main DDoS threat is transaction flooding
- Most blockchains have a fixed capacity because they create blocks with a certain maximum size at regular intervals
- Anything that doesn't fit in the current block will be stored in mempools for consideration for the next block
- If an attacker sends many blockchain transactions containing negligible values to the network, they can fill up blocks with spam transactions causing legitimate transactions to sit in mempools

DDoS attack in blockchain

- The P2P nature of any blockchain system means these spam transactions sent multiple times by different nodes creating a congestion in the network
- On September 14, 2021, the Solana blockchain was offline for several hours
- The root cause of this issue was a DDoS attack caused by the launch of a new project on the blockchain
- When the project was launched, bots started generating large amounts of transactions that flooded the network

Blockchain Governance

- Governance is a structure through which a participant or user of a system uses and participates in the system
- Almost every social structure has some sort of governance
- Governments are a prime example of how governance functions
- There are different types of governments and modes of governance
- There are three entities that dictate governance
 - Rulers
 - Rules
 - Participants

Blockchain Governance

- Simply, the ruler set the rules based on the participant's goals and needs
- For any governance system to work properly, all the three elements need to work together and play nicely without interrupting the other
- You can look at big countries, for example, to understand the different governance models
- China's approach is different as they have a one-party governance system
- Other countries deploy a democratic approach where people decide their government

Blockchain Governance

- There are two types of Governance in Blockchain:
 - Off-chain governance
 - On-chain governance

Off-chain Governance

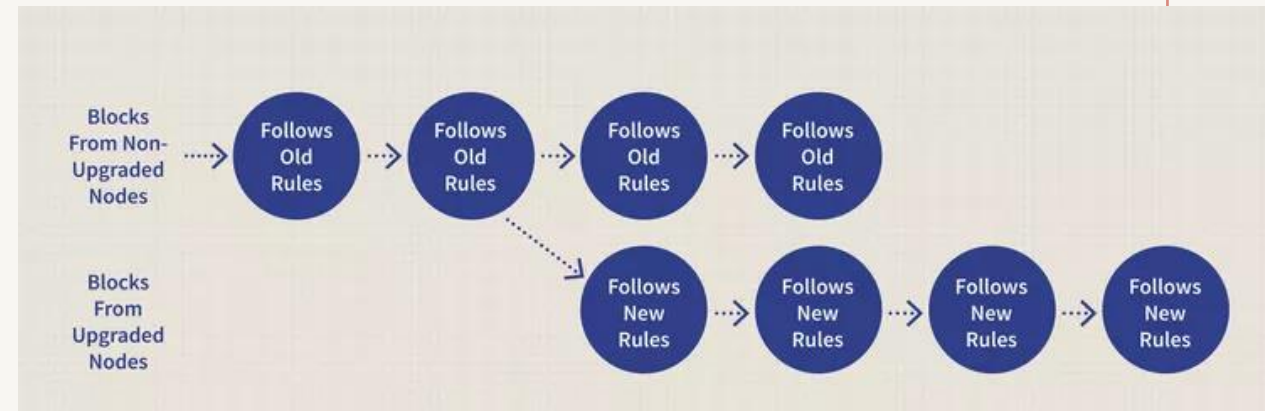
- In an off-chain Governance model, all the major changes proposed to a blockchain system are thoroughly discussed online by key stakeholders
- The key stakeholders include the core development team, other developers, miners/stakers, researchers, and the end-user community
- Bitcoin and Ethereum use this model
- In this model, major changes are proposed as improvement proposals known as Bitcoin Improvement Proposal (BIP) or Ethereum Improvement Proposal (EIP)
- The core development team of the blockchain system holds regular online meetings where anyone is welcome to participate
- As per their discussion, a particular BIP or EIP is chosen

Off-chain Governance

- The corresponding proposal is then developed in the core code base of the blockchain system
- Now then question is: how to introduce this in the live blockchain system?
- In a traditional system, the software/server is placed under maintenance and becomes offline
- However, a live blockchain can never be down for a single moment
- Everyone is requested to update the core software
- The requested change is set to be activated in future from a certain block onwards

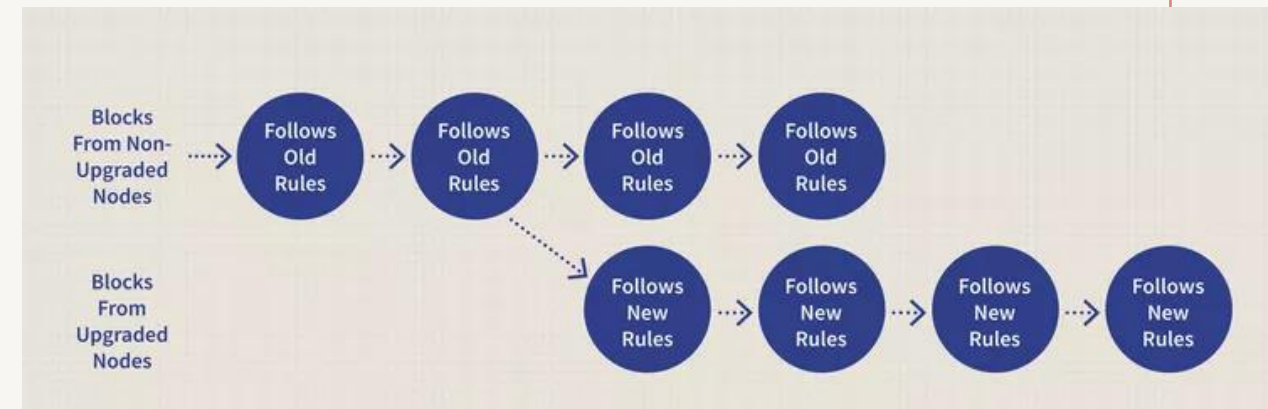
Off-chain Governance

- Adopting a particular proposal essentially creates a fork in the system
- There could be two such forks: hard fork and soft fork



Off-chain Governance

- A hard fork refers to a radical change to the protocol of a blockchain network that effectively results in two branches, one that follows the previous protocol and one that follows the new version
- In a hard fork, miners must choose which blockchain to continue verifying
- With a soft fork, only one blockchain will remain valid as users adopt the update



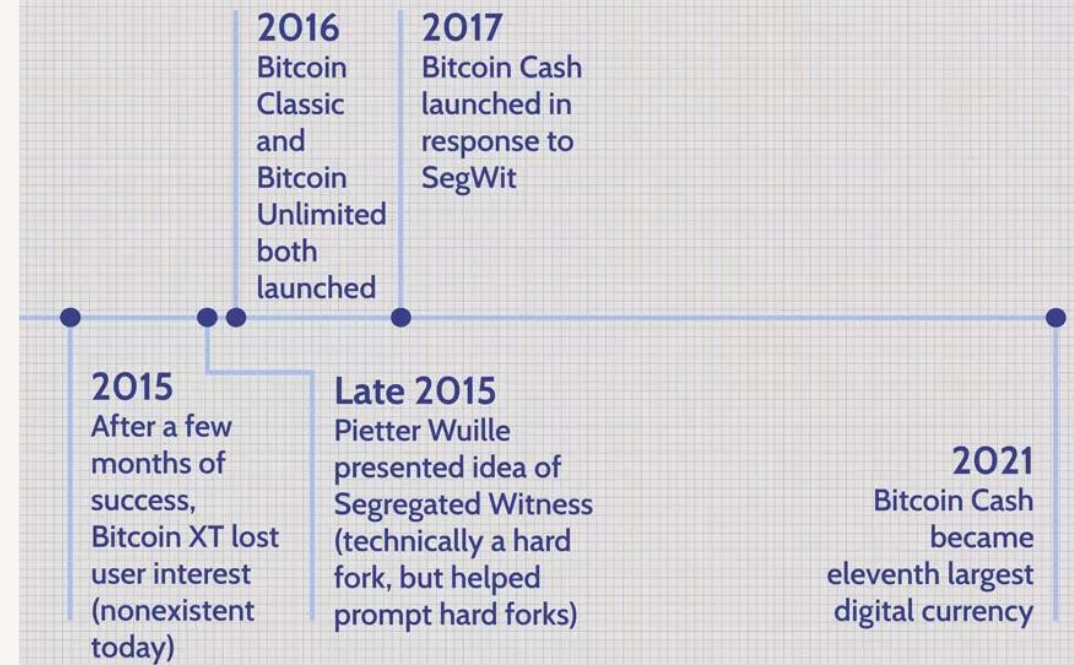
Off-chain Governance

- How this change is adopted entirely depends on the miners/stakers adopting this particular change
- Miners update their software to signal that they agree to this particular change
- If there are some miners who do not agree to a particular proposal, they might continue mining on the previous branch
- An interesting case is the Bitcoin fork

Off-chain Governance

- In order to scale Bitcoin, many argued to increase the block size
- This resulted in a number of Bitcoin forks
- Notable is the Bitcoin Cash launched in 2017, created in response to SegWit
- SegWit (Segregated Witness): reducing transaction size so that more transactions could be accommodated without modifying bitcoin block size
- Bitcoin Cash introduced 8MB block size

Bitcoin Hard Forks History



On-chain Governance

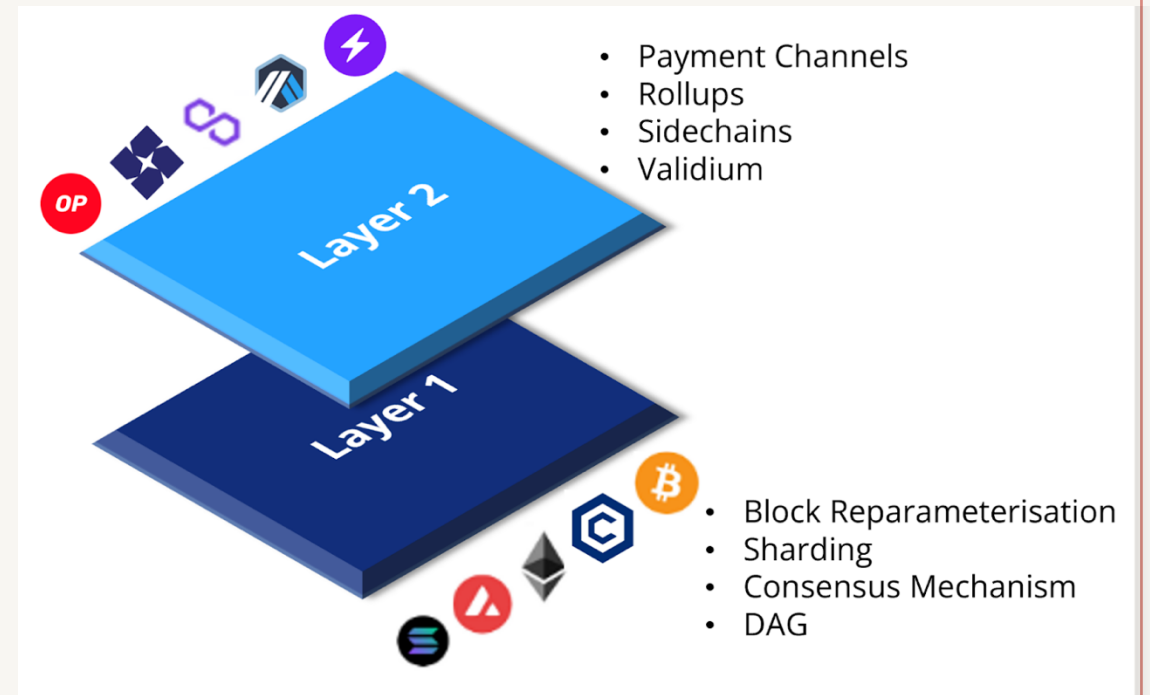
- On-chain governance is a system for managing and implementing changes via blockchain systems
- Developers propose changes through code updates and each node or participant votes on whether to accept or reject the proposed change
 - These votes are stored on-chain
- Typically, on-chain governance involves the following stakeholders: Miners, Developers and Users
- Stakeholders in the process are provided economic incentives to participate
- For example, each node can earn a cut of overall transaction fees for voting, while developers are rewarded through alternate funding mechanisms

Advanced concepts

- Three major advanced concepts to address the scalability and privacy issues of blockchain
 - Layer 2 solution
 - Sharding
 - ZKP (Zero-knowledge Proof)

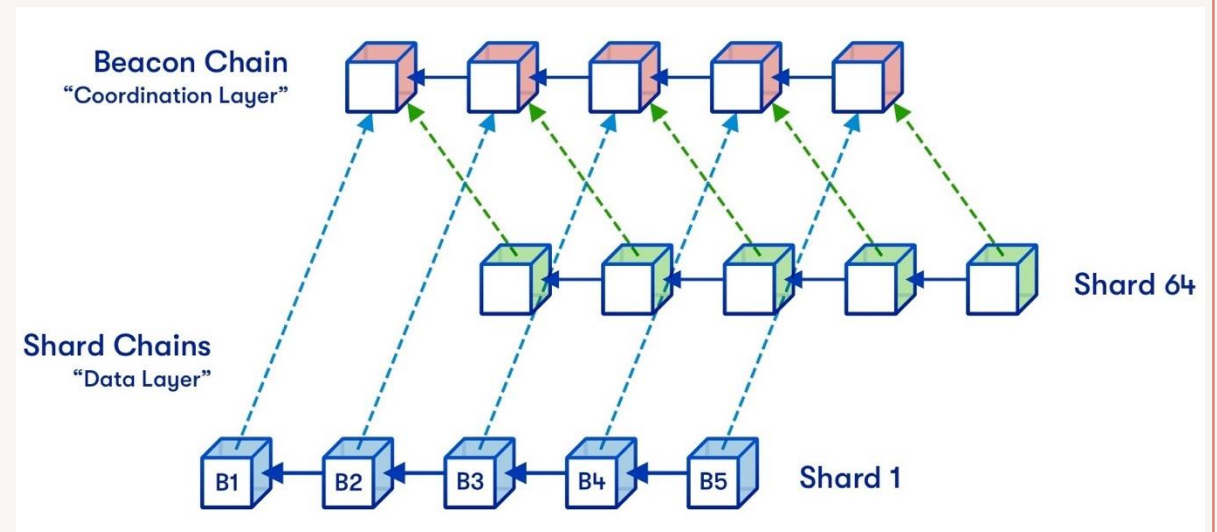
Layer 2 solution

- Layer-1 refers to the main blockchain
- Layer-2, however, is an overlaying network that sits on top of the blockchain
- Lightning Network is the Layer-2 solution for Bitcoin
- Plasma, Polygon, Optimism, and Arbitrum are just a few of the Layer-2 networks built on Ethereum



Sharding

- Sharding is a method of database partitioning that is utilised by blockchain organisations to increase scalability
- This enables them to execute a greater number of transactions per second and store data across multiple nodes in a sustainable way



ZKP (Zero-knowledge Proof) in blockchain

- ZKP is a method by which one party can interact with another party and provides proof of knowledge without unveiling their confidential data
 - Say there are two millionaire and they would like to determine who is richer without revealing their total assets
 - Logging in to an online system without providing passwords
- ZKP facilitates this by using advanced cryptographic mechanisms
- In blockchain, ZKP facilitates private transactions and others
 - Nobody in the blockchain knows who is the sender and who is the receiver
- Example: ZCash

